Sensibiliser à la protection des données



Obligations

Non seulement, il est nécessaire de former les acteurs d'une organisation à la protection des données, mais il s'agit aussi d'une obligation légale.

Une des missions du délégué à la protection des données consiste à « contrôler le respect du présent règlement [...] en matière de protection des données à caractère personnel, y compris en ce qui concerne la répartition des responsabilités, la sensibilisation et la formation du personnel participant aux opérations de traitement, et les audits s'y rapportant. »

https://www.cnil.fr/fr/reglement-europeen-protection-donnees/chapitre4#Article39

Moyens

2 moyens de sensibilisation à la protection des données à caractère personnel :

- Formation
- Documentation

Sensibilisation

Formation / Documentation



Formation

Nombreux sont les membres d'une organisation qui manipulent des données personnelles sans même en avoir conscience. C'est pourquoi vous devez dans un premier temps questionner les personnes sur leur définition et sur leur gestion des données à caractère personnel.

L'idéal est d'effectuer un premier test avant le début de la sensibilisation en demandant aux personnes de répondre aux questions sans s'aider d'outils tels qu'Internet. Ce test vous permettra d'adapter votre support à la connaissance de vos auditeurs.

Documentation

Cette documentation est essentielle pour la conformité au RGPD, en appui à la formation.

Sous forme de fiches, elle doit être ludique, claire, accessible et mise à jour régulièrement.

Il faut éviter de créer un document unique contenant toutes les informations. Il vaut donc mieux créer des fiches courtes reprenant les éléments principaux si possible à l'aide de schémas.

Communication

Il est indispensable d'effectuer des rappels sur l'existence de cette documentation, par exemple à travers un bulletin d'information ou par mail.



Responsabilisation



DPO

DPO : Data Protection Officer
En français, délégué à la protection des données

La sensibilisation doit être complétée par une responsabilisation des acteurs du SI.

La réglementation stipule que « le responsable du traitement met en œuvre des mesures techniques et organisationnelles appropriées pour s'assurer et être en mesure de démontrer que le traitement est effectué conformément au présent règlement »

https://www.cnil.fr/fr/reglement-europeen-protection-donnees/chapitre4#Article24

DPO

En résumé, le responsable de traitement doit :

- s'assurer que les traitements de données à caractère personnel respectent le RGPD ;
- apporter la preuve que le RGPD est respecté dans l'organisation

Collaborateurs

Les formations et les fiches sont insuffisantes dans l'implication des collaborateurs. C'est pourquoi il faut les responsabiliser, en incluant, par exemple, des clauses spécifiques liées aux traitements des données à caractère personnel dans les contrats de travail.

Prestataires

Ce type de clause devra aussi figurer dans les contrats avec les prestataires extérieurs dans lesquels ils s'engagent à mettre tout en œuvre pour sécuriser les données qui leur sont transmises ainsi qu'à faire preuve de vigilance dans leur traitement.

Charte informatique

Il est utile de faire signer une charte informatique à tous les utilisateurs du SI en y incluant un engagement au respect du RGPD et notamment aux règles suivantes :

- ne pas utiliser les données à des fins autres que celles prévues ;
- ne transmettre les données qu'à des tiers dûment autorisés ;
- ne pas faire de copie des données sauf dans les besoins du traitement ;
- prendre toutes les mesures nécessaires pour que l'utilisation de ces données soit conforme aux attributions du collaborateur ;
- prendre toutes les précautions conformes à l'usage pour préserver la sécurité physique et logique de ces données ;
- s'assurer, dans la limite de ses attributions, que seuls les moyens de communication sécurisés seront utilisés pour transférer ces données;
- en cas de cessation de ses activités, le collaborateur devra restituer intégralement les données, fichiers informatiques et tout support d'information relatif à ces données.

Un travail d'équipe



Encadrement

La mise en place du RGPD est un processus sur le long terme qui peut modifier fortement les pratiques et bouleverser les routines de travail.

Ainsi, elle doit s'accompagner d'actions de suivi et de contrôle des connaissances sur les pratiques en vigueur.

Ces suivis et contrôles peuvent s'effectuer au travers de questionnaires dont les réponses permettront d'identifier les points faibles et de mettre en place des formations ou documents adéquats.

Coopération

Les différents acteurs doivent aussi avoir le réflexe de signaler tout dysfonctionnement ou amélioration concernant les traitements des données personnelles.